

Semester Campus EdTech Vendor Intake Policy

Policy owner: Trust, Risk, and Compliance Lead

Approvers: Security, Privacy, Accessibility, AI Governance, Procurement, Legal, and the designated Institutional Business Owner

Review cadence: At least annually and after material changes to policy, law, technology, or institutional risk posture

Status: Draft template — requires institution-specific legal and records review before adoption

1. Purpose

This policy establishes a consistent process for evaluating third-party education technology, artificial-intelligence services, integrations, content providers, and related cloud services before they process institutional, student, faculty, staff, or operational data; authenticate users; integrate with institutional systems; or support institutional workflows.

The policy is designed to protect learners, preserve institutional authority, support accessibility, reduce security and privacy risk, and make vendor decisions evidence-based. It uses the Higher Education Community Vendor Assessment Toolkit (HECVAT), relevant 1EdTech TrustEd Apps materials, accessibility documentation, interoperability evidence, and an AI-governance overlay as complementary inputs.

2. Scope

This policy applies to new, renewed, materially changed, pilot, departmental, centrally procured, free, freemium, open-source hosted, and externally integrated services that may:

- Process institutional, student, faculty, staff, applicant, alumni, or partner information.
- Receive education-record information or other personal information.
- Authenticate through SSO, provision accounts, or access institutional identity data.
- Connect to LMS, SIS, gradebook, roster, calendar, file-storage, payment, messaging, analytics, or data-warehouse systems.
- Use generative AI, machine learning, automated decision support, content detection, proctoring, monitoring, or agentic/tool-action features.
- Deliver instructional content, assessment, grading, community, mentoring, student support, accessibility, career, payment, or communication functions.

3. Principles

All vendor reviews must apply the following principles:

1. **Student-centered purpose.** The service must address a defined academic, operational, accessibility, or student-support need.

2. **Minimum necessary data.** Collect, share, and retain only the data required for the approved purpose.
3. **Institutional authority.** A vendor may support workflows but may not make official academic, financial-aid, disciplinary, accommodation, health, legal, or other high-impact decisions unless separately authorized by law and institution policy.
4. **Accessibility by default.** Accessibility is a release, procurement, and support requirement—not an optional add-on.
5. **Standards and portability.** Prefer interoperable, documented, exportable, standards-based products over closed or lock-in-dependent products.
6. **Transparent AI.** AI use, providers, data practices, limitations, and human-review boundaries must be clear.
7. **Evidence over assertions.** A policy statement alone does not demonstrate that a control operates.
8. **Proportional review.** The depth of review must match data sensitivity, integration scope, user impact, and operational risk.
9. **No shadow adoption.** Departments may not enable covered services with institutional data or identity integration outside this process.
10. **Continuous oversight.** Approval is not permanent; material changes, incidents, renewals, and new data uses require reassessment.

4. Roles and decision rights

Role	Responsibilities
Requester	Defines the business need, intended users, data, integrations, timeline, and institutional owner; does not approve their own risk exception.
Business owner	Accountable for value, workflow ownership, user communication, training, and ongoing service review.
Procurement	Manages vendor engagement, contracts, pricing, approved purchasing process, and renewal timing.
Security	Reviews security architecture, identity, infrastructure, SDLC, vulnerability management, incident response, and integration security.
Privacy/Legal	Reviews data uses, FERPA and applicable privacy issues, DPAs, retention, subprocessors, disclosures, and contractual controls.
Accessibility	Reviews ACR/VPAT, accessibility evidence, known barriers, alternatives, remediation commitments, and assistive-technology testing.
AI Governance	Reviews AI inventory, providers, training/retention, data flows, evaluation, misuse controls, human oversight, and change management.
Integration Architecture	Reviews LTI, OneRoster, SSO, SCIM, APIs, webhooks, data minimization, rate limits, reconciliation, and offboarding.
Risk Committee / executive delegate	Approves high-risk exceptions, critical pilots, residual-risk acceptance, and material policy deviations.

5. Intake requirements

Every request must include:

Vendor and product name

Business purpose and success measure

Institutional business owner

User populations

Requested launch date and contract term

Data categories and sensitivity

Integration requirements

Authentication/provisioning requirements

AI features, providers, and external actions

Accessibility impact

Whether grades, assessments, payments, community safety, basic needs, minors, health, or other high-risk workflows are involved

Existing alternatives and reason they are insufficient

6. Risk tiering

Tier	Definition	Examples	Review requirement
Low	No institutional personal data, no SSO, no integration, no AI, no consequential workflow	Public informational tool with no account	Basic legal/privacy/accessibility review
Moderate	Limited directory/profile data, low-risk instructional or operational purpose, limited authentication or import	Low-risk course tool with SSO but no grades	Privacy, security, accessibility, integration review as applicable
High	Education-record data, student-generated content, SSO/SCIM/LTI/SIS connection, AI, assessment, community, or broad user population	LMS tool, advising tool, AI study service	Full evidence package and cross-functional approval
Critical	Financial, health, basic-needs intake, minors, proctoring, grading, broad production export, agentic actions, high-stakes decisions, or sensitive data	Payment processor, proctoring tool, AI agent with write access	Full review, DPIA/PIA, threat model, legal review, executive approval, strict launch gates

7. Required evidence

All covered vendors

Current privacy policy and terms of service

Accessibility statement

Data categories and data-use description

Subprocessor/third-party disclosure

Security contact and incident contact

Retention/deletion approach

Moderate and high-risk vendors

- Current HECVAT workbook at the institution-requested level, where applicable
- 1EdTech TrustEd Apps certifications or self-assessment materials, where available
- Current ACR/VPAT and known-accessibility-limitation statement
- Architecture and data-flow diagram
- DPA and standard contract terms
- Incident-response and business-continuity summary
- Integration/API documentation and data scopes
- Data-export/offboarding guide
- Independent security assessment or penetration-test executive summary, where available

AI-enabled vendors

- AI feature inventory
- Model/provider/version list
- Input/output, retrieval, and tool-action data flow
- Training, retention, and secondary-use terms
- Hosting and processing locations
- User notice and applicable opt-in/opt-out controls
- Human-review and high-impact-decision boundaries
- Safety, security, prompt-injection, data-leakage, bias, and accessibility approach
- Evaluation/monitoring methodology
- AI incident and change-management process

8. Review workflow

- Request submitted
 - completeness and risk-tier review
 - evidence request
 - secure evidence-vault intake
 - framework/control mapping
 - security, privacy, accessibility, AI, legal, and integration review
 - findings, risks, required clauses, configuration restrictions, and remediation plan
 - approval decision
 - contract completion
 - implementation and launch gates
 - periodic monitoring and renewal reassessment

9. Approval outcomes

Outcome	Meaning
Approved	Evidence and controls meet the applicable risk requirements.
Approved with conditions	Approval depends on defined remediation, configuration restrictions, contractual terms, or launch gates.
Pilot only	Limited duration and scope; use synthetic/de-identified data where feasible; no production integration unless explicitly approved.

Outcome	Meaning
Deferred	Business purpose, ownership, evidence, or data scope is not sufficiently defined.
Not approved	Risk, control gap, contractual position, or unsupported workflow is unacceptable.

10. Contract and configuration requirements

For applicable vendors, contracts and implementation plans must address:

Permitted data use and prohibited secondary use
 No sale of student data
 No general-purpose model training on production institutional/student data by default
 Subprocessor notice and control
 Security safeguards and breach/incident notice
 Data location and transfer commitments
 Retention, deletion, legal hold, export, and offboarding
 Accessibility commitments and remediation process
 Interoperability, API, integration scope, and data minimization
 Support, uptime, incident communications, and escalation
 Audit/cooperation rights as appropriate
 Intellectual property and content ownership
 Termination, transition assistance, and secure credential revocation

11. Launch gates

A high- or critical-risk service may not go live until:

A named business owner and technical owner exist.
 Applicable privacy, security, accessibility, AI, legal, and integration reviews are complete.
 Contract/DPA requirements are complete.
 The data map and retention configuration are approved.
 SSO/integration scope is tested in a sandbox or controlled environment.
 Least-privilege roles and privileged-access controls are configured.
 Accessibility acceptance criteria and known limitations are documented.
 AI policy, provider, and evaluation controls are approved where applicable.
 Support, incident escalation, and customer/student communications are ready.
 Export/offboarding and credential-revocation procedures are documented.
 Open findings are accepted, remediated, or formally risk-accepted by authorized leadership.

12. Monitoring, renewal, and reassessment

Approved vendors must be reviewed:

At renewal.
 At least annually for high- and critical-risk services.
 After a material product, AI model/provider, data-use, hosting, or subprocessor change.
 After a material security, privacy, accessibility, or safety incident.
 Before expanding data scope, users, integrations, or external actions.

Review evidence includes updated HECVAT/assurance material where required, revised ACR/VPAT, current subprocessors, security/AI changes, incident history, accessibility remediation status, integration health, and offboarding readiness.

13. Exceptions

Exceptions require:

- Documented business justification
- Risk analysis and compensating controls
- Named risk owner
- Defined expiry date
- Approval at the correct authority level
- User/customer disclosure if appropriate
- Remediation plan and target date
- Reassessment before expiry

No exception may permit undisclosed data sale, unlawful data use, an unreviewed high-impact automated decision, or a critical accessibility or security risk without authorized executive and legal review.

14. Records and transparency

The institution will retain vendor intake decisions, submitted evidence references, review notes, findings, approvals, exceptions, contracts, implementation evidence, and reassessment records according to the applicable records-retention schedule and legal-hold process.

Students, faculty, and staff should receive clear notices when a service materially affects their information, course workflow, assessment, AI use, or accessibility options. Notices should explain the service purpose, official authority boundaries, privacy controls, support route, and available alternatives where required.

15. Policy review

This policy is reviewed annually by Procurement, Security, Privacy/Legal, Accessibility, AI Governance, and representative academic/student-service stakeholders. Material changes require versioning, approval, communication, and training updates.